

Understand before you click.

An explainable, browser-based screening tool for suspicious emails. Designed for initial triage, learning and evidence review.

What the system does

Mail Lens evaluates an email using **30 deterministic rules across five categories**. It returns a 0-100 risk index, the triggering evidence, plain-English explanations, category contributions and missing checks. It does not use a trained classifier or claim a measured detection accuracy.

Category	Evidence examined
Social engineering	Urgency, credentials, payments, changed bank details, secrecy, remote access and QR instructions.
URLs & HTML	Actual destination hosts, misleading labels, IP literals, shorteners, internationalized domains and active HTML.
Sender identity	From, Reply-To, Return-Path and an optional independently known official domain.
Authentication claims	SPF, DKIM and DMARC values in pasted Authentication-Results headers.
Attachment clues	Executable, double-extension, macro, archive and direction-control clues in filenames or body text.

Privacy by design

Email input stays in the current browser page. The application makes no network requests with the pasted content and does not save it to browser storage. URLs are shown as inert text, and pasted HTML is never rendered or executed. Loading the application or downloading this guide still involves ordinary website requests.

Use the result as a reason to investigate

A high score is a warning, not proof of fraud. A low score is not proof of safety. Sophisticated messages, compromised legitimate accounts and attacks contained in images or attachments can evade these rules.

Supply context. Review evidence.

The quality of the assessment depends on what you paste and which independent facts you can provide.

1. Import the original message

Choose an EML file or drop it into the import area (maximum 10 MB). MIME parts, base64, quoted-printable and declared character sets are decoded locally. You can also paste complete email source or import an HTML / TXT file.

2. Preserve links and add context

Ordinary paste keeps clipboard HTML when available, including hidden button targets. If only plain text is supplied, a warning explains the missing coverage. Add an independently known official domain and any missing sender or header information.

3. Read the decision and score breakdown

Review the risk band, capped category contributions and triggered rules. Each finding includes evidence, a raw weight and an explanation that mentions plausible benign causes.

4. Inspect what remains unknown

Coverage distinguishes checked inputs from missing inputs. Authentication values are labeled as claims. The URL inventory identifies actual hostnames without opening the destinations.

5. Verify through an independent channel

For sensitive requests, use a known official app, a saved bookmark or an established contact. Avoid relying on phone numbers or verification links supplied by the suspicious message. [1]

Input and parsing boundaries

EML import fills From, Subject, raw headers and attachment names. Both HTML and plain-text MIME alternatives are retained. Import replaces the current message and clears the expected domain; failed imports preserve the previous inputs. Authentication-Results remains an unverified claim.

Decoded body limit: 100,000 characters; headers: 50,000. Oversize imports are rejected without truncation. HTML/TXT files must be UTF-8. MSG, encrypted messages, PDF, image/QR content and attached emails are not analyzed. Attachments are not opened or scanned.

Transparent weights, bounded totals.

Rule weights and thresholds are product design choices. They have not been calibrated against a labeled phishing dataset.

Risk index = $\min(100, \text{sum of category contributions})$

Each category contribution is $\min(\text{category cap, sum of triggered rule weights})$. Each rule adds points only once. Up to three evidence snippets are retained per rule.

Category	Maximum contribution
Social engineering	40
URLs & HTML	40
Sender identity	25
Authentication claims	25
Attachment clues	25

Score	Decision	Interpretation
0-19	Few detected signals	No safety verdict; continue normal verification.
20-49	Review required	Resolve suspicious clues before sensitive actions.
50-100	High risk	Pause interaction and verify / report.

Why the method uses caps

Correlated clues can exaggerate a naive sum. For example, an executable with a double extension triggers two file rules (25 + 25), but Attachment clues contributes at most 25. Repeating the same suspicious URL or phrase does not increase a rule weight.

Missing data is not exculpatory evidence

Omitted headers, unavailable attachments or an absent expected domain do not add or subtract points. Instead, the coverage panel records the gap. Passing authentication claims also do not subtract points.

Authentication requires a trust boundary

An Authentication-Results field reports an upstream system's assertions. Its presence does not make those assertions trustworthy. Mail Lens cannot establish the trusted receiving boundary or verify SPF, DKIM or DMARC; it only parses the pasted claims. Multiple or conflicting claims need review in the receiving service. [2]

What contributes to the score

All 30 rules are listed below. Weights are raw; category caps and the global cap apply afterward.

Category / cap	Rule	Weight
Social engineering / 40	Urgency or account threat	10
Social engineering / 40	Request for credentials or sensitive data	30
Social engineering / 40	Payment or reward request	15
Social engineering / 40	Changed payment instructions	25
Social engineering / 40	Secrecy or isolation pressure	15
Social engineering / 40	Remote access or protection bypass	20
Social engineering / 40	QR code used for account action	10
URLs & HTML / 40	Unencrypted HTTP URL	8
URLs & HTML / 40	User information before @ in a URL	25
URLs & HTML / 40	Numeric IP destination	20
URLs & HTML / 40	Known URL shortening service	12
URLs & HTML / 40	Internationalized domain name	12
URLs & HTML / 40	Nonstandard web port	8
URLs & HTML / 40	Displayed URL differs from destination	30
URLs & HTML / 40	URL outside the expected domain	15
URLs & HTML / 40	Expected domain embedded in another host	20
URLs & HTML / 40	Active HTML or embedded form	25
Sender identity / 25	Reply-To hostname differs from From	12
Sender identity / 25	Return-Path hostname differs from From	5
Sender identity / 25	Sender outside the expected domain	20
Sender identity / 25	Display-name address differs from mailbox	20
Sender identity / 25	Multiple From claims	15
Authentication claims / 25	Pasted DMARC failure claim	25
Authentication claims / 25	Pasted SPF fail or softfail claim	10
Authentication claims / 25	Pasted DKIM failure claim	15
Attachment clues / 25	Executable or script filename	25
Attachment clues / 25	Document-like name ending in executable extension	25
Attachment clues / 25	Macro-enabled file or enable-macros request	20
Attachment clues / 25	Archive or disk image filename	8
Attachment clues / 25	Bidirectional control character	20

Interpret a result responsibly.

The built-in samples use reserved example domains. Their scores illustrate rule behavior, not benchmark accuracy.

Sample	Result	Why
Account alert	100 / High risk	Social engineering 40, URLs 40, identity 20 and authentication claims 25 total 125, capped at 100.
Payment fraud	52 / High risk	Payment, bank-change and secrecy clues reach the content cap of 40; different Reply-To adds 12. Pasted passing authentication does not cancel them.
Meeting invite	0 / Few detected signals	No rules trigger. This is still not a verified safe email.

Known limitations and false positives

Legitimate password resets, payment workflows, marketing redirects, support platforms, internationalized domains and archives can trigger rules. Exact hostname comparisons are not public-suffix-aware organizational alignment checks. A trusted-looking From address can be forged or compromised.

Not performed: DNS or WHOIS lookups; domain age or reputation checks; redirect expansion; cryptographic email authentication; malware scanning; archive extraction; QR/image analysis; full semantic or multilingual understanding. English and selected Chinese phrase patterns are supported.

If someone has already interacted

Change exposed credentials through the official service, notify your security team and follow its incident response process. If a payment was sent, contact the bank or payment provider promptly. Preserve the original email for investigation. [1]

Validation and future evaluation

Functional checks verify MIME decoding, hidden-link preservation, clipboard handling, scoring caps and rejection of unsupported or oversized inputs. They do not establish real-world accuracy. A future evaluation should use separately labeled benign and phishing samples, measure false positives and false negatives, and calibrate thresholds before production use.

References

[1] NIST, *Phishing*, updated August 19, 2025.

nist.gov/itl/smallbusinesscyber/guidance-topic/phishing

[2] IETF RFC 8601, *Message Header Field for Indicating Message Authentication Status*, May 2019, Sections 1.1-1.3.

rfc-editor.org/rfc/rfc8601.html

Sources accessed September 11, 2026. Neither source endorses the scoring weights.